Industrial Security (Bachelor)

Exercise Sheet – Section 04

Industrial Protocols

Goal. These scenarios put you in front of real wire formats and real plant misconfigurations. You should leave the sheet able to read a Modbus frame at the byte level, recognise the failure mode of each major industrial protocol, and choose the correct compensating control when the protocol itself offers none. Every answer should refer to a concrete mechanism on the wire or in a config file, not a generic "apply security" statement.

Exercise 4.1 – Decode a Modbus TCP Request

Capture the following 12-byte Modbus TCP request off the wire:

```
00 01   00 00   00 06   11   03   00 6B   00 03
```

1. Name every MBAP header field and give its value.
2. Identify the function code and state in one sentence what it does.
3. What is the unit identifier and which register range is being read?
4. Compute the expected length (in bytes) of a successful response, and the value the `Length` field of that response must carry.

Exercise 4.2 – EtherNet/IP Scan Took the Line Down

A blue-team engineer accidentally allowed an EtherNet/IP `ListIdentity` scan from the IT side through the IDMZ firewall. Three minutes later the ControlLogix PLC at the end of the conduit stopped responding and operators hit the emergency stop. List the *three* most plausible root causes for the PLC freeze and, for each, describe what you would look for in the Wireshark PCAP to confirm or rule it out (one to two sentences per cause).

Exercise 4.3 – Hardening a Mosquitto Broker

An IIoT pilot ships with a Mosquitto broker listening on the default `1883/tcp` with anonymous publish and subscribe enabled. Write the *four* lines you would add to `mosquitto.conf` to bring it to a minimum-acceptable security baseline. For each line, explain in one sentence why it matters. Assume you already have a CA, a server certificate, and a password file generated with `mosquitto_passwd`.

Exercise 4.4 – "Use OPC UA, It Is Secure"

A vendor proposes OPC UA for a greenfield line and tells the project manager "it is secure, you do not have to worry". List the *four* configuration choices that decide whether an OPC UA deployment is actually secure or only nominally so. For each choice, name the insecure default that real-world deployments are repeatedly caught using.

Exercise 4.5 – Why Modbus Has No Authentication

Modbus was published in 1979 and is still ubiquitous in 2026. Explain in three to five sentences:

1. the historical reason there is no authentication, integrity, or confidentiality in the protocol;

2. the modern compensating-control pattern that real plants use to live with this gap (name the layers involved, not just "a firewall").

Exercise 4.6 – Reading a DNP3 Trace

You are handed a PCAP slice from a substation. The first frame shows TCP port `20000`, DNP3 start bytes `05 64`, direction bit indicating outstation-to-master, source address `5`, destination `1`, application function code `0x82` (*Unsolicited Response*) and an object header for class 1 events. Five further frames of the same shape follow within 50 ms, all from address `5`.

1. Interpret what this traffic is in operational terms.
2. Identify one anomaly worth investigating and explain how you would confirm whether it is benign or hostile.

Exercise 4.7 – Profinet vs. Modbus: Fail-Closed?

On the same Ethernet segment you have a Profinet RT cyclic exchange between a controller and an IO device (cycle time 4 ms) and a Modbus TCP poll between an HMI and a PLC (poll interval 500 ms). A switch port flaps for 800 ms.

1. Which exchange fails closed first, and why? Tie your answer to the timing and the protocol's watchdog behaviour.
2. Give one safety implication on the plant floor.

Exercise 4.8 – Compensating for Unauthenticated GOOSE

IEC 61850 GOOSE messages trip breakers in under 4 ms and carry no authentication by default. List *three* compensating controls you can deploy, ranked from *lowest cost / least intrusive* to *highest cost / most intrusive*. For each, state one drawback the protection engineer will raise.

Exercise 4.9 – Spot the Bug in a Modbus Client

The following pseudocode polls a PLC every 100 ms:

```
loop forever:
s = socket(); s.connect((plc, 502));
s.send(read_holding_registers(0, 10));
data = s.recv(); s.close();
sleep(0.1)
```

1. Describe the impact on the PLC under sustained polling. Be specific about the PLC-side resource that is exhausted and the symptom an operator will see.
2. State the standard fix and why it is also recommended by the Modbus Organization.

Exercise 4.10 – Three Security Models Side by Side

Build a comparison table with one row per dimension and one column per protocol. Rows: *Authentication*, *Integrity*, *Confidentiality*, *Key management*. Columns: *OPC UA (`Basic256Sha256`)*, *MQTT over TLS*, *Profinet Security (IEC 62443-aligned profile)*. Fill every cell with the concrete mechanism (e.g. `X.509 mutual`, `HMAC-SHA256`, `AES-GCM`, `PKI with GDS`). Below the table, write three to four sentences on which model is hardest to operate at scale and why.